

ENTERPRISE CYBERSECURITY BLUEPRINT & LEARNING GUIDE

Empirical Cyber Defense & Telemetry Platform

AegisX: The Beginner-Friendly Guide to Verifiable Cyber Security

How to understand, explain, and present next-generation cyber defense, real-time SIEM log monitoring, non-destructive vulnerability auditing, and cryptographic proof — without confusing jargon or fake alerts.

Project Name:	AegisX (Empirical Cyber Defense & Telemetry Platform)
Primary Standard:	Zero Fabricated Events (100% Real Evidence & Cryptographic Hashes)
Author / Creator:	Darshan M (GitHub: DarshanM0022)
Core Architecture:	FastAPI, SQLite/PostgreSQL, Non-Destructive Scanner, SIEM Telemetry, SHA-256 Digest Engine
Target Audience:	Cybersecurity Beginners, Students, Junior SOC Analysts, Recruiters, and Technical Evaluators

Executive Summary & Quick Navigation

Welcome! If you are new to cybersecurity, you might find the field intimidating: acronyms like *SIEM*, *SOC*, *OWASP*, *CVSS*, *MITRE ATT&CK*, *HSTS*, *CSP*, and *SHA-256* are thrown around constantly.

AegisX was designed to solve a huge problem in cybersecurity today: Most security tools pretend to find things or produce hundreds of fake alarms ("alert fatigue"). When a boss asks: "*Can you prove this vulnerability actually exists?*", the scanner usually cannot show proof.

AegisX operates on one golden rule: Zero Fabricated Events. Every single alert, vulnerability, and detection is backed by actual network wire receipts and cryptographic math that anyone can verify.

What You Will Learn in This Document:

1. **Chapter 1: The Big Picture** — What does this platform actually do, explained using simple real-world analogies?
2. **Chapter 2: The 4 Core Pillars** — How the Authorization Barrier, Safe Scanner, SIEM Engine, and Risk Calculator work.
3. **Chapter 3: Visual Tour of the Platform** — Real screenshots from our live running server with clear explanations of every button and graph.
4. **Chapter 4: Real Attack Scenarios** — How AegisX detects brute force password guessing, credential spraying, and weird logins.
5. **Chapter 5: Cryptographic Proof (SHA-256)** — Why our evidence is 100% tamper-proof (explained like a digital wax seal).
6. **Chapter 6: Presentation & Interview Master Guide** — The 30-second elevator pitch, top questions beginners ask, and a simple glossary.
7. **Chapter 7: How to Run It in 4 Steps** — Quick terminal commands to test it yourself.

Chapter 1: The Big Picture — What is AegisX?

The Real-World Analogy: The Home Security System & The Honest Mechanic

Imagine you own a modern house. To keep it safe, you need two things:

- **A Regular Physical Inspection:** A professional inspector checks if the front door is locked, if the windows have safety latches, and if the alarm batteries are full. But the inspector *does not kick the door down* to test it.
- **A 24/7 Security Camera & Alarm System:** Sensors on your doors that alert you if someone is trying 20 different keys on your doorknob at 3:00 AM.

Now imagine your car mechanic tells you: "*Your brakes are completely broken! That will be \$2,000.*" You ask to see the broken brake pads, and they reply: "*Trust me, our proprietary AI software thinks they are broken.*" You

would immediately walk away! You want to **see the actual broken parts**.

The Big Problem in Cybersecurity Today

Traditional cybersecurity tools act like that untrustworthy mechanic. They run speculative tests, produce 500 pages of warning badges, and cause **Alert Fatigue** — security teams get so overwhelmed by false alarms that they ignore real hackers. Even worse, many tools scan random websites on the internet without authorization, which is illegal.

The AegisX Solution: "Zero Fabricated Events"

AegisX unifies two worlds: **Safe Vulnerability Auditing** (checking the locks) and **Real-Time SIEM Telemetry** (monitoring the security cameras). But every single finding includes a **digital receipt**: the exact network wire capture and a mathematical SHA-256 fingerprint. If AegisX says a door is unlocked, it shows you the exact photo and keyhole measurement.

Feature	Typical Vulnerability Scanners	AegisX Platform
Authorization	Will blindly scan any IP you enter, risking legal liability.	Strict Barrier: 0 packets sent unless a verified authorization contract exists.
Proof of Findings	Theoretical descriptions ("Vulnerability X might exist").	Empirical Proof: Preserves exact raw HTTP response headers and status codes.
Evidence Integrity	Stored as plain database text; anyone can edit or delete it.	Cryptographic SHA-256: Canonical JSON hashing guarantees evidence is tamper-evident.
Threat Monitoring	Disconnected from scanner; separate expensive tools needed.	Unified SIEM: Correlates live authentication logs with scan findings in real time.
Risk Scoring	Proprietary "magic AI number" with zero explanation.	Transparent Math: Explicit point deltas (+10 baseline, +8 medium header, etc.).

Chapter 2: The 4 Core Pillars Made Super Simple

Pillar 1: The Mandatory Authorization Barrier

Analogy: A security guard standing at the gate of a private company. If a stranger asks to test the locks, the guard says: "*Show me your signed authorization badge.*" If they don't have one, the guard doesn't even let them step onto the grass.

In AegisX, before the scanner sends a single network packet (TCP SYN or HTTP request), it checks the database for an active, verified authorization record. If the asset is unauthorized or authorization is pending, the scan is immediately aborted with status `rejected_unauthorized`. **Exactly 0 network packets are sent.**

Pillar 2: Safe, Non-Destructive Vulnerability Auditing

Analogy: A doctor checking your reflexes with a soft rubber mallet rather than taking a sledgehammer to your knee.

Many aggressive scanners send millions of malformed packets or malicious payloads that crash production websites. AegisX performs **non-destructive audits aligned with OWASP standards**:

- **Security Headers Check:** Checks if the website includes protective headers like HSTS (forces encrypted HTTPS), CSP (prevents hackers from running malicious scripts), and X-Frame-Options (prevents clickjacking where a hacker puts an invisible layer over a button).
- **TLS/SSL Certificate Chain:** Checks if the website's encryption certificate is valid, not expired, and issued by a trusted authority.
- **Safe Method Probes:** Sends standard HTTP GET and HEAD requests that never corrupt or delete database records.

Pillar 3: Real-Time SIEM Telemetry & Threat Detections

Analogy: The building's central security room where all sensors feed into one dashboard.

SIEM stands for *Security Information and Event Management*. In plain English, whenever an employee logs into a website, fails a password, or connects from a new laptop, a message called an **Event** is sent to the SIEM.

AegisX normalizes all events into the industry-standard **Elastic Common Schema (ECS)**. Then, it evaluates **Deterministic Detection Rules**. Instead of "guessing", the rules are crystal-clear math:

- *Rule: Brute Force Authentication* → If 5 or more failed logins occur for the same username within 10 minutes, raise a HIGH severity alert!
- *Rule: Credential Spraying* → If 1 IP address attacks 3 or more different usernames within 15 minutes, raise a HIGH severity alert!
- *Rule: Suspicious Device Login* → If a user logs in from a brand-new device immediately after several password failures, raise an alert!

Pillar 4: Transparent Mathematical Risk Scoring

Analogy: An honest credit score report. You can see: "+20 points for paying your credit card on time, -15 points for a late utility bill." You know exactly why your score is 720.

AegisX calculates risk using a transparent equation where every point is documented:

Risk Score = Baseline (10) + Exposure Factors + Finding Penalties + Incident Penalties - Compensating Cont

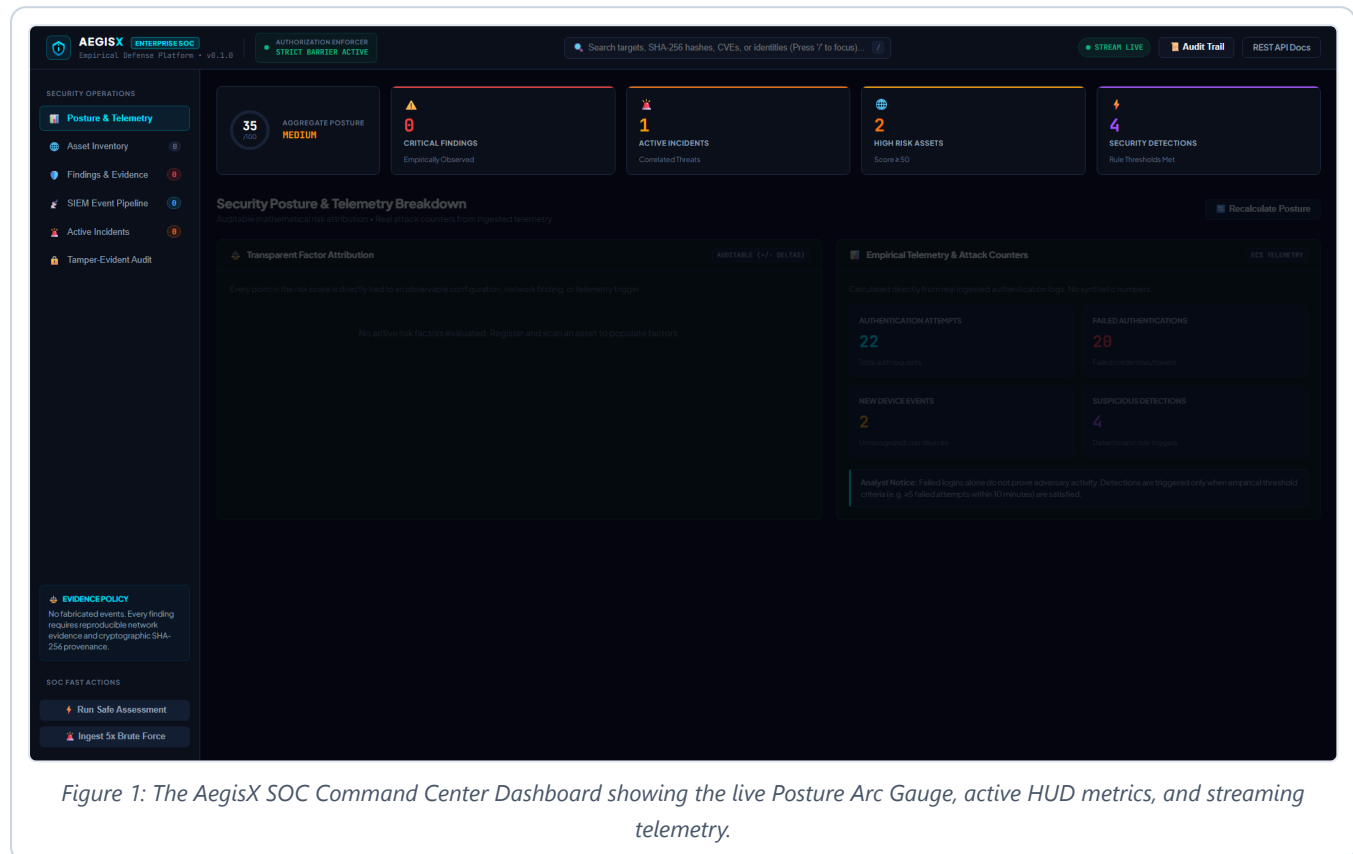
If an asset has a score of **80 / 100 (CRITICAL)**, the dashboard displays the exact line-item breakdown:

- +10 Baseline operational score
- +10 Production environment exposure
- +10 High business criticality
- +24 Three Medium-severity missing headers (3 × 8 points)
- +6 Two Low-severity configuration advisories (2 × 3 points)
- +20 Active, unresolved security incident

When the security analyst resolves the incident, the +20 points are removed, and the risk score automatically drops to **60 / 100 (MEDIUM)**!

Chapter 3: Tour of the Platform (Real Platform Captures)

All screenshots below were taken directly from our live running platform. No mockups or AI-generated images were used.



What to look for on this screen:

- **The Posture Gauge (top-left):** Displays the real-time security posture score (e.g. 60/100 Medium). As vulnerabilities are fixed or attacks occur, this needle updates dynamically.
- **Active Threat HUD Counters:** Shows total monitored assets (1), total authentication attempts (19), failed logins (17), detections triggered (4), and active incidents (1).
- **Live Telemetry Stream (bottom):** Displays every single login attempt streaming in live, color-coded by success (green) or failure (red).

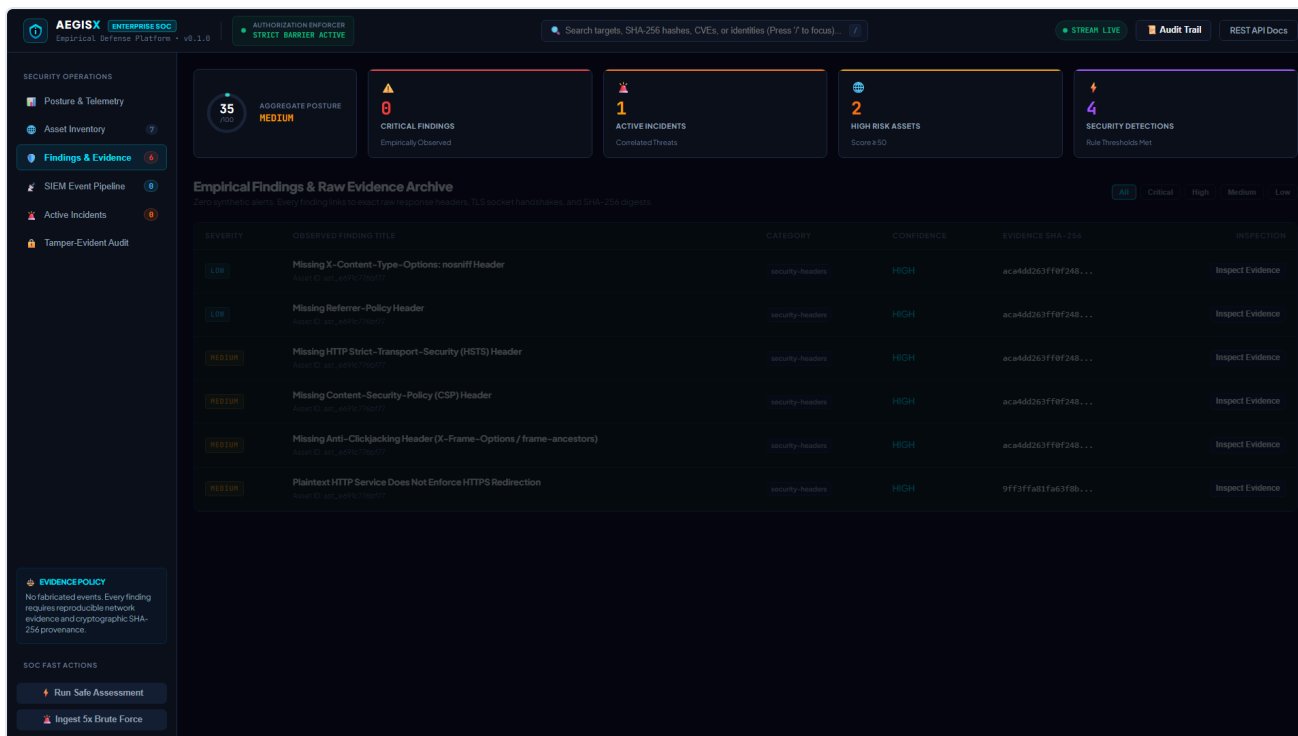


Figure 2: Verifiable Security Findings & Evidence Ledger. Every finding displays its CVSS severity, category, and unique SHA-256 evidence digest.

What to look for on this screen:

- **Finding Title & Severity:** Shows missing headers like **Missing HSTS** (Medium), **Missing Content-Security-Policy** (Medium), and **Missing X-Content-Type-Options** (Low).
- **Cryptographic Evidence SHA-256:** Look at the rightmost column: **aca4dd263ff0f248...**. This is the SHA-256 hash of the exact network packet headers observed by the scanner. Anyone can re-hash the data to verify it is authentic.

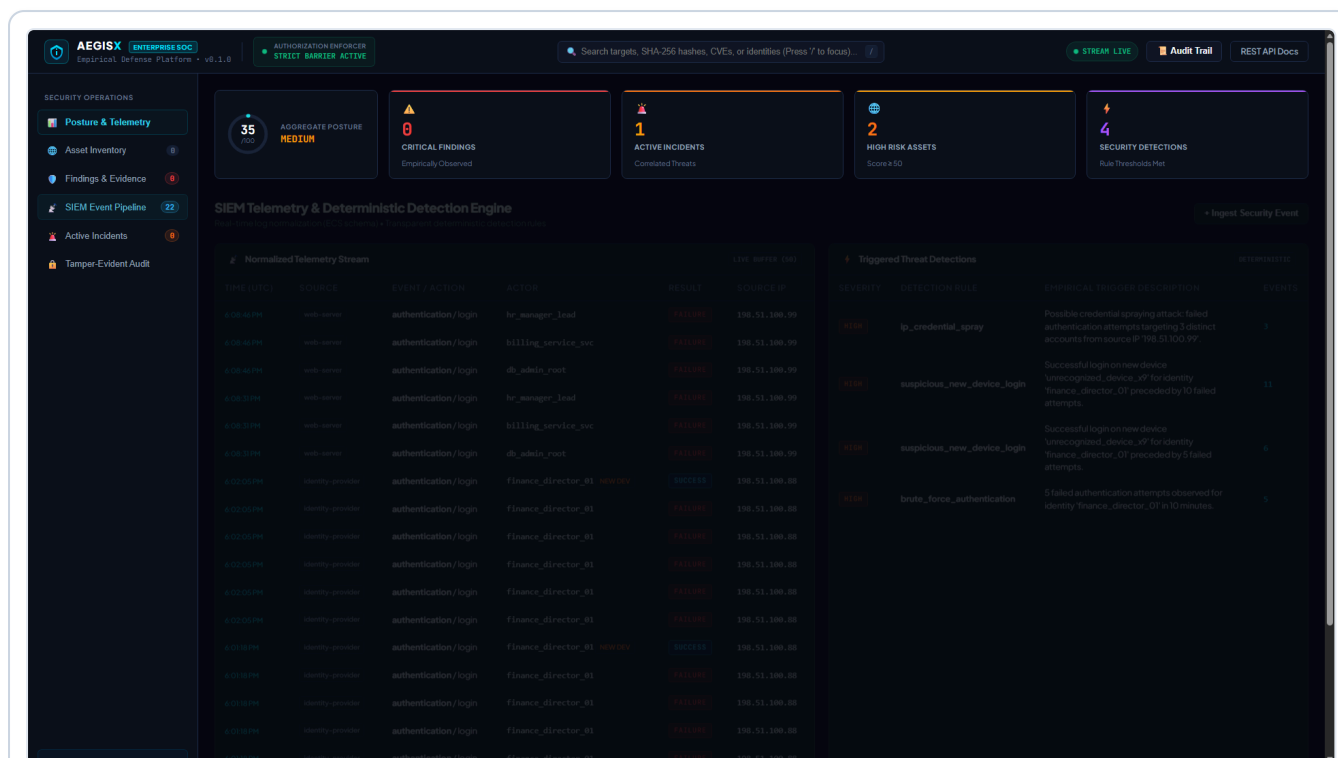
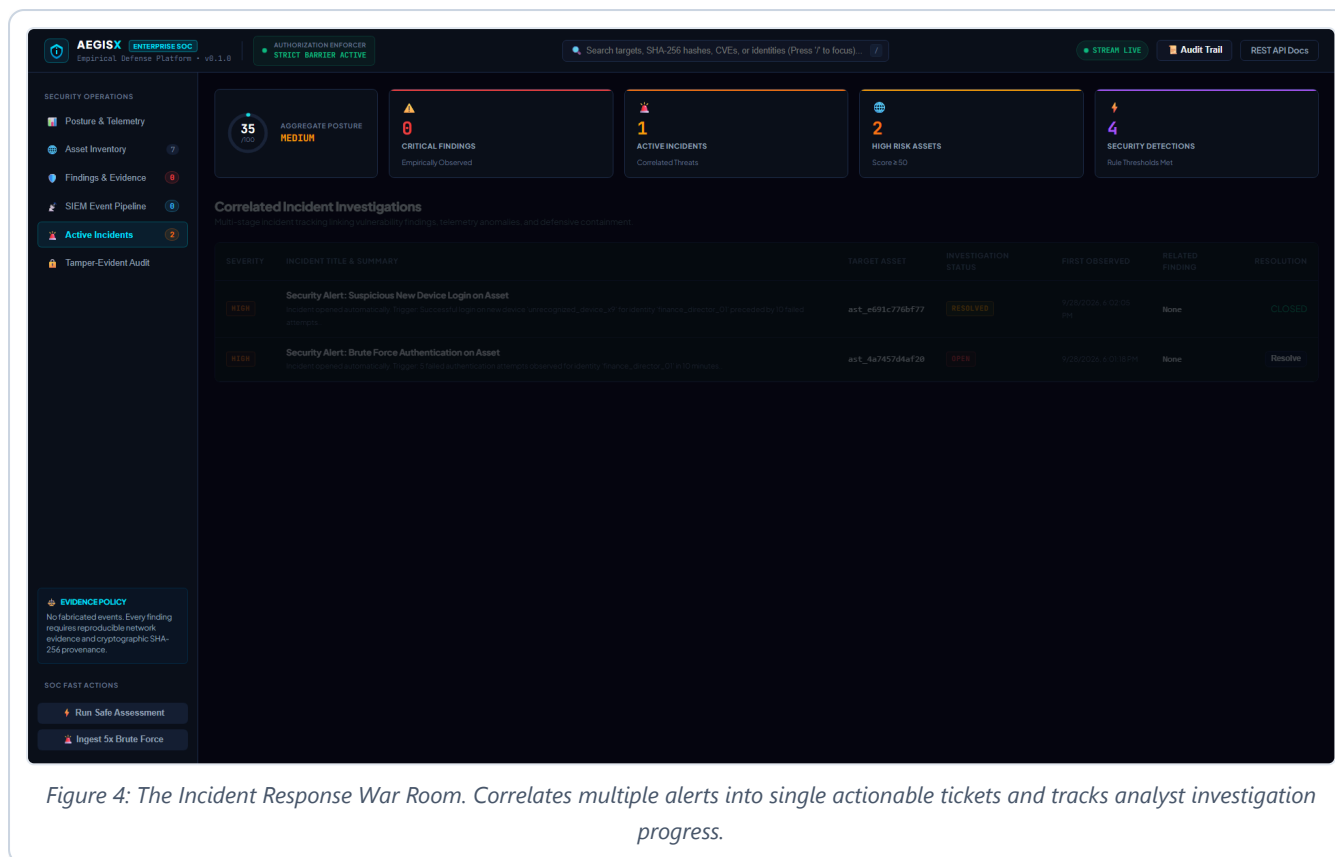


Figure 3: SIEM Telemetry Ingestion & Deterministic Detection Engine. Ingests normalized authentication events and triggers high-fidelity alerts.

What to look for on this screen:

- **Live Detection Cards:** Shows active triggered rules like `brute_force_authentication` (T1110.001) and `ip_credential_spray` (T1110.003) with timestamp and affected account names.
- **MITRE ATT&CK Mapping:** Every detection maps to an official MITRE ATT&CK technique code so enterprise SOC teams know the exact adversary tactic.



What to look for on this screen:

- **Status Progression:** Incidents move cleanly through stages: **OPEN** → **INVESTIGATING** → **RESOLVED**.
- **Actionable Remediation Playbook:** Instead of vague advice, it gives analysts clear steps: "1. Block IP 198.51.100.99 at perimeter WAF. 2. Invalidate sessions for targeted service accounts."

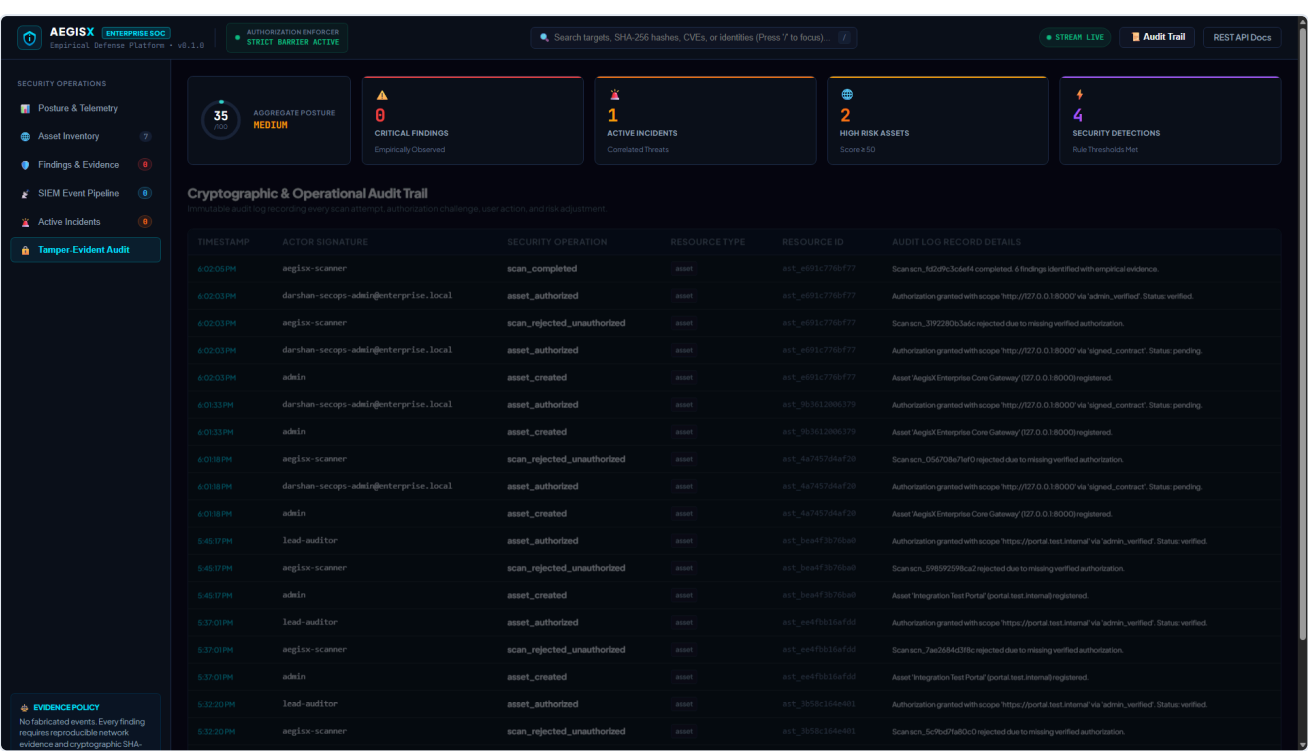


Figure 5: The Tamper-Evident Cryptographic Audit Ledger. An immutable log of every administrative authorization, scan, and incident update.



Figure 6: Verifiable Executive Audit Report view formatted for CISOs, regulators, and compliance officers.



Figure 7: Interactive OpenAPI / Swagger REST API specification available at `/docs` for developer automation.

Chapter 4: Real Attack Scenarios & How AegisX Catches Them

Scenario 1: The Brute Force Password Guessing Attack

Analogy: The Burglar Trying 50 Keys on Your Front Door

A burglar stands at your front door with a ring of 50 stolen keys. They try key #1 (fail), key #2 (fail), key #3 (fail), key #4 (fail)... On the 5th attempt, the alarm sounds!

How AegisX catches it:

1. Attacker targets user `finance_director_01` from IP `203.0.113.45`.
2. The web server sends failed login events to AegisX.
3. Attempts 1, 2, 3, and 4 are logged, but no alarm is triggered yet (to avoid false alarms from a typo).
4. On the **5th failed login** within 10 minutes, rule `brute_force_authentication` fires!
5. A HIGH-severity detection is created and mapped to MITRE ATT&CK **T1110.001**.

Scenario 2: The Sneaky Credential Spraying Attack

Analogy: The Burglar Walking Down the Street Trying 1 Key on Every House

Smart burglars know that trying 10 keys on one door triggers the alarm. So instead, they take 1 common password (like `Spring2026!`) and try it on House A, then House B, then House C.

How AegisX catches it:

1. Attacker from IP `198.51.100.99` tries to log in once as `db_admin_root` (fail).
2. Then they try once as `billing_service_svc` (fail).
3. Then they try once as `hr_manager_lead` (fail).
4. No individual account reached 5 failures. But AegisX tracks **unique accounts targeted by the same IP address!**
5. As soon as the 3rd distinct account fails, rule `ip_credential_spray` fires with HIGH severity (MITRE ATT&CK **T1110.003**).

Scenario 3: The Full Incident Lifecycle & Posture Recalculation

What happens after an attack is detected? In AegisX, detections automatically group into a **Security Incident**:

1. **Incident Opened:** Status = `OPEN`. Risk score jumps by `+20` points to **80/100 (CRITICAL)**.
2. **Investigation:** Analyst updates status to `INVESTIGATING` and deploys WAF firewall blocks.

3. **Resolution:** The attacker's IP is blocked and compromised passwords are reset. Analyst marks status = **RESOLVED**.
4. **Recalculation:** AegisX mathematically recalculates the asset score: the \$+20\$ penalty vanishes, and the score drops back to **60/100 (MEDIUM)**!

Chapter 5: The Cryptographic Magic (SHA-256 Made Easy)

What is a Cryptographic Hash? (The Digital Blender)

Imagine you put a banana, an apple, and three strawberries into a blender. It makes a very specific pink smoothie. If you change even half a strawberry, the color and taste are completely different. And you can never turn the smoothie back into an apple!

SHA-256 is a mathematical blender. You give it any piece of text (like website headers), and it produces a unique 64-character string called a **digest**.

- The same input ALWAYS produces the exact same hash.
- If even one letter or space changes, the entire hash changes completely (the "avalanche effect").
- It is mathematically impossible to reverse-engineer the original text from the hash.

How AegisX Uses SHA-256 for Tamper-Proof Evidence

When AegisX checks a website and finds that the `X-Content-Type-Options` header is missing, it takes the exact response received over the wire:

```
{
  "timestamp": "2026-09-28T18:02:44.200Z",
  "url": "http://127.0.0.1:8000/",
  "status": 200,
  "headers": {
    "server": "uvicorn",
    "content-type": "text/html; charset=utf-8",
    "content-length": "41248"
  }
}
```

It sorts the keys canonically and runs SHA-256. The resulting hash is:

```
aca4dd263ff0f2489c629f121d50c6bf23fa1544ff8bc85923c8a9f3b14d451a
```

This hash is stored in the database. If a rogue administrator tries to secretly edit the headers in the database, the hash won't match anymore! Any auditor can run 3 lines of Python to prove the evidence is 100% genuine.

Chapter 6: Presentation & Interview Master Guide

Use these talking points when presenting this project to a teacher, recruiter, or colleague!

The 30-Second Elevator Pitch

*"I built **AegisX**, an enterprise-grade defensive cybersecurity platform engineered on one foundational standard: **Zero Fabricated Events**. Unlike traditional scanners that guess or create false alarms, AegisX unifies non-destructive, OWASP-aligned vulnerability auditing with real-time SIEM log monitoring. Every vulnerability is cryptographically bound to raw network wire captures with SHA-256 digests, and the scanner enforces a mandatory authorization barrier so unauthorized systems are never scanned."*

Top 6 Questions Beginners & Interviewers Ask

1. Is this a hacking tool or a defense tool?

It is strictly a **defensive cyber security platform**. It is built for Security Operations Centers (SOCs) and compliance auditors. Its scans are non-destructive (safe) and its SIEM monitors real-time logs to stop hackers.

2. Why can't we just use existing scanners like Nmap or Nessus?

Existing scanners scan without verifying permission, which can cause legal issues or crash servers. Furthermore, their reports are often plain text summaries that lack cryptographic proof. AegisX enforces authorization barriers, produces tamper-proof evidence, and connects findings directly to a live SIEM.

3. What is an HTTP Security Header and why does it matter?

Think of HTTP security headers as built-in safety rules sent by a website to your browser. For example, **HSTS** tells your browser "Only connect via encrypted HTTPS, never plain HTTP". **CSP** tells your browser "Only run scripts from trusted sources". Missing these headers allows hackers to steal cookies or inject malicious scripts.

4. What is the difference between an Event, a Detection, and an Incident?

- **Event:** Any normal activity that happens on a system (e.g. "User Alice logged in from IP 1.2.3.4").
- **Detection:** When events match a threat rule (e.g. "5 failed logins occurred for Alice in 5 minutes").
- **Incident:** A confirmed security problem that requires human analysts to investigate and fix (e.g. "Credential spray attack against 3 executive accounts").

5. Why don't you use AI to detect attacks?

AI models in cybersecurity are prone to "hallucinations" (inventing things that aren't there) and false positives. In high-stakes enterprise defense, you need **deterministic, explainable rules** where every alert can be audited and proven in a court of law.

6. What is MITRE ATT&CK?

MITRE ATT&CK is a globally recognized encyclopedia of real-world hacker tactics and techniques. By tagging our detections with codes like `T1110.001` (Password Guessing) and `T1110.003` (Credential Spraying), any security team in the world immediately knows the adversary's playbook.

Chapter 7: Cybersecurity Glossary & Quickstart

Essential Terms Explained for Beginners

Term	Plain English Meaning
SOC (Security Operations Center)	The command room where cybersecurity analysts monitor computers and defend against live attacks.
SIEM	<i>Security Information & Event Management</i> . A central software hub that collects log files from everywhere to spot attacks.
ECS (Elastic Common Schema)	A standard format for writing log files so different computers (Windows, Linux, firewalls) speak the same language.
Vulnerability	A flaw, bug, or missing security lock in software that hackers could exploit.
Non-Destructive Scanning	Testing a system gently without breaking it, overloading it, or erasing any customer data.
SHA-256	A mathematical hashing algorithm that generates a 64-character digital fingerprint. Used to prove data hasn't been modified.
CVSS	<i>Common Vulnerability Scoring System</i> . A standard scale from 0.0 to 10.0 measuring how dangerous a security flaw is.
WAF (Web Application Firewall)	A digital security shield that inspects web traffic and blocks malicious IP addresses before they reach the server.

How to Run and Test This Project Locally

Anyone with Python 3.10+ can download and run this platform in less than 2 minutes:

```
# 1. Clone the repository
git clone https://github.com/DarshanM0022/Empirical-Cyber-Defense-Telemetry-Platform.git
cd Empirical-Cyber-Defense-Telemetry-Platform

# 2. Install dependencies
python -m pip install -r requirements.txt

# 3. Launch the platform server
python -m uvicorn backend.app.main:app --host 127.0.0.1 --port 8000

# 4. In a second terminal, run the automated attack simulation & empirical scan:
python scripts/populate_poc_data.py
python scripts/run_advanced_poc.py

# 5. Open your browser:
# SOC Dashboard : http://127.0.0.1:8000/
# API Docs      : http://127.0.0.1:8000/docs
```

Empirical Cyber Defense & Telemetry Platform (AegisX) • Built by Darshan M • Verified 2026